

4. Linux Privilege Escalation (CTF/Boot2Root)

Setelah mendapatkan akses user biasa pada mesin CTF/lab, tujuan berikutnya adalah mencari cara meningkatkan hak akses hingga user lain atau root.

Contoh posisi awal:

```
www-data@target:/var/www/html$
```

atau

```
john@target:~$
```

Saat ini kamu belum root.

Konsep Utama

Privilege Escalation bukan tentang menjalankan exploit secara membabi buta.

Prinsipnya:

Enumerasi

↓

Temukan misconfiguration

↓

Analisis

↓

Naik privilege

90% keberhasilan berasal dari enumerasi.

Checklist Enumerasi Pertama

Begitu mendapat shell:

```
whoami
```

```
id
```

```
hostname
```

```
uname -a
```

Contoh:

```
uid=33(www-data)
```

Berarti masih user biasa.

Enumerasi Sistem

Kernel

```
uname -a
```

atau

```
cat /etc/os-release
```

Contoh:

Ubuntu 18.04

Catat versinya.

Enumerasi User

```
cat /etc/passwd
```

Contoh:

```
root
john
alice
www-data
```

User menarik:

```
john
alice
```

Karena biasanya memiliki home directory.

Enumerasi Home Directory

```
ls /home
```

Misal:

```
john
alice
```

Cek permission:

```
ls -la /home/john
```

Cari:

```
notes.txt
passwords.txt
backup.zip
```

Enumerasi Sudo

Perintah paling penting:

sudo -l

Contoh:

User john may run:
(ALL) NOPASSWD: /usr/bin/vim

Ini temuan besar.

Catat untuk analisis lebih lanjut.

Enumerasi SUID

Cari file SUID:

find / -perm -4000 2>/dev/null

Contoh:

/usr/bin/passwd
/usr/bin/find
/usr/bin/vim

SUID adalah topik khusus yang akan kita bahas setelah ini.

Enumerasi Cron

Cari cron job:

crontab -l

atau

cat /etc/crontab

Contoh:

* * * * * root /opt/backup.sh

Jika file tersebut bisa ditulis user biasa, itu sangat menarik.

Cron juga akan kita bahas terpisah.

Enumerasi Service

ps aux

Cari:

mysql

apache
python
backup
custom

Kadang ada service buatan developer yang rentan.

Enumerasi Network

ss -tulpn

atau

netstat -tulpn

Contoh:

127.0.0.1:3306
127.0.0.1:8080

Service lokal kadang menyimpan kredensial atau petunjuk.

Enumerasi File Menarik

Cari file konfigurasi:

find / -name "*.conf" 2>/dev/null

Cari file backup:

find / -name "*.bak" 2>/dev/null

Cari file password:

find / -iname "*pass*" 2>/dev/null

Enumerasi Environment Variables

env

Kadang muncul:

DB_USER=admin
DB_PASS=secret123

Ini sering terjadi pada aplikasi web.

Enumerasi History

cat ~/.bash_history

Kadang developer lupa menghapus:

mysql -u root -pSuperSecret

Enumerasi SSH

ls -la ~/.ssh

Cari:

id_rsa
authorized_keys

Kadang ada private key yang bisa dipakai berpindah ke user lain.

LinPEAS

Tool paling terkenal untuk enumerasi Linux:

[LinPEAS Project](https://github.com/peass-ng/PEASS-ng?utm_source=chatgpt.com)

Dalam CTF biasanya dijalankan setelah mendapat shell untuk membantu menemukan:

SUID menarik

Cron job

Password

Capability

Writable file

Weak permission

Jangan langsung percaya hasilnya; tetap analisis sendiri.

Prioritas Saat Mendapat Shell

Urutan yang saya sarankan untuk LKS:

1. whoami
2. id
3. sudo -l
4. find SUID
5. cat /etc/crontab
6. ls /home

7. env
8. ps aux
9. ss -tulpn
10. LinPEAS

Contoh Kasus

Misal kamu mendapatkan:

```
www-data@target$
```

Lalu:

```
sudo -l
```

Hasil:

```
Sorry, user www-data may not run sudo
```

Tidak ada jalan dari sudo.

Lanjut:

```
find / -perm -4000 2>/dev/null
```

Hasil:

```
/usr/bin/find
```

Nah, sekarang fokus berpindah ke topik berikutnya:

5. SUID Abuse

Karena ini adalah teknik privilege escalation yang paling sering muncul dalam Boot2Root dan LKS. Di sana kita akan belajar cara menganalisis file SUID, mengenali mana yang berbahaya, dan bagaimana mengidentifikasi jalur eskalasi dalam lingkungan CTF/lab.